

数据库系统原理

胡 敏 教授 博士生导师
合肥工业大学 计算机与信息学院
jsjxhumin@hfut.edu.cn

第4章 数据库安全性



厚德 笃学 崇实 尚新

第4章 数据库安全性

问题的提出

- 数据库的一大特点是数据可以共享，数据共享必然带来数据库的安全性问题。
- 数据库系统中的数据共享不能是无条件的共享的。

例如： 军事秘密、国家机密、新产品实验数据、
市场需求分析、市场营销策略、销售计划、客户档案、医疗档案、银行储蓄数据
，等等。



第4章 数据库安全性

4.1 数据库安全性概述

4.2 数据库安全性控制

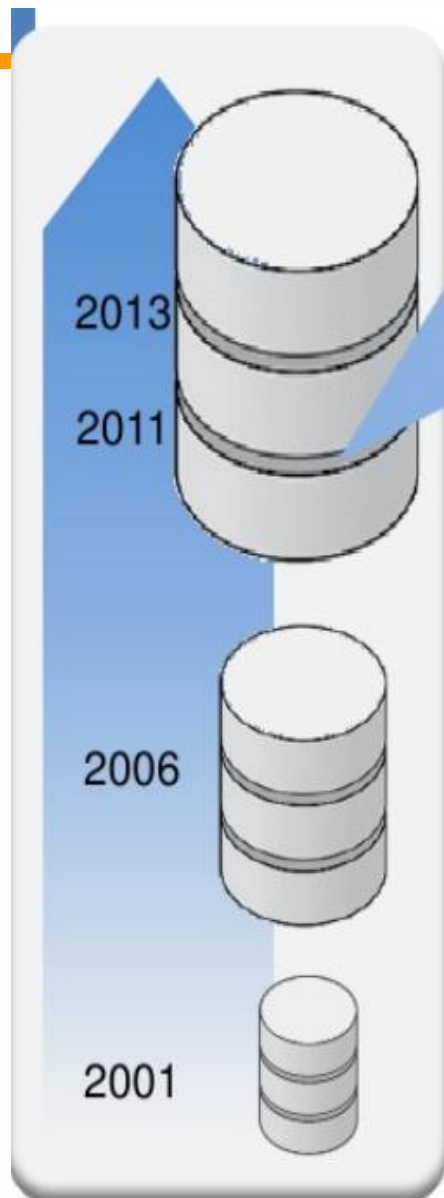
4.3 视图机制

4.4 审计 (Audit)

4.5 数据加密

4.6 小结





超过78%的敏感数据
存在数据库中!

Source: "Effective Data Leak Prevention Programs: Start by Protecting Data at the Source — Your Databases", IDC, August 2012

98% 的敏感数据获取的行
为和途径是数据库服务器

Source: "Verizon Business 2012 Data Breach Investigations Report", Verizon, June 2012

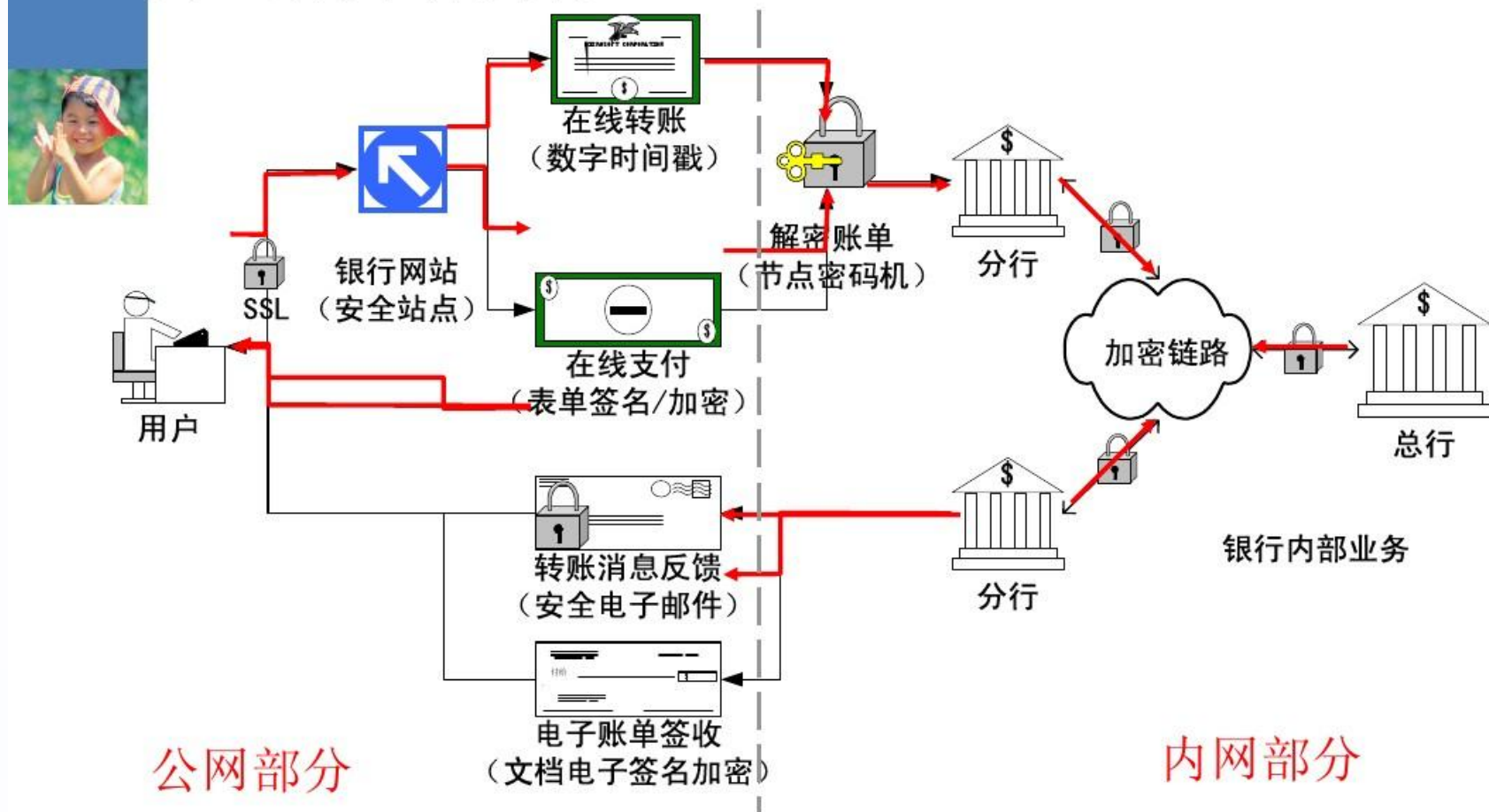
Table 10. Compromised assets by percent of breaches and percent of records*

Type	Category	All Orgs	Larger Orgs
POS server (store controller)	Servers	50% 1%	2% <1%
POS terminal	User devices	35% <1%	2% <1%
Desktop/Workstation	User devices	18% 34%	12% 36%
Automated Teller Machine (ATM)	User devices	8% <1%	13% <1%
Web/application server	Servers	6% 80%	33% 82%
Database server	Servers	6% 96%	33% 98%
Regular employee/end-user	People	3% 1%	5% <1%
Mail server	Servers	3% 2%	10% 2%
Payment card (credit, debit, etc.)	Offline data	3% <1%	0% <1%
Cashier/Teller/Waiter	People	2% <1%	2% <1%
Pay at the Pump terminal	User devices	2% <1%	0% <1%
File server	Servers	1% <1%	5% <1%
Laptop/Netbook	User devices	1% <1%	5% <1%
Remote access server	Servers	1% <1%	7% <1%
Call Center Staff	People	1% <1%	7% <1%

*Assets involved in less than 1% of breaches are not shown

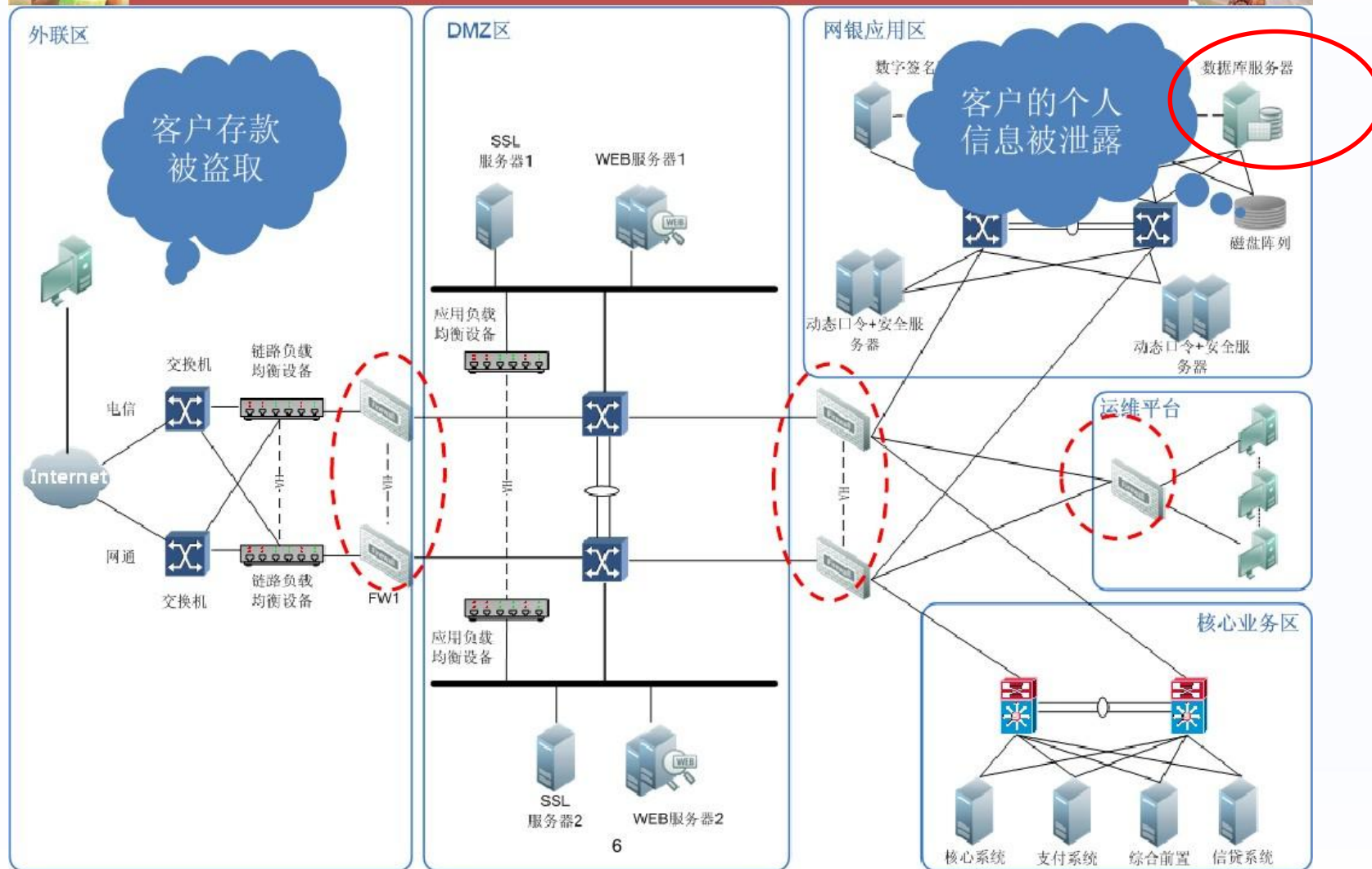


看看严格的安全系统怎么做的？：网银安全解决方案



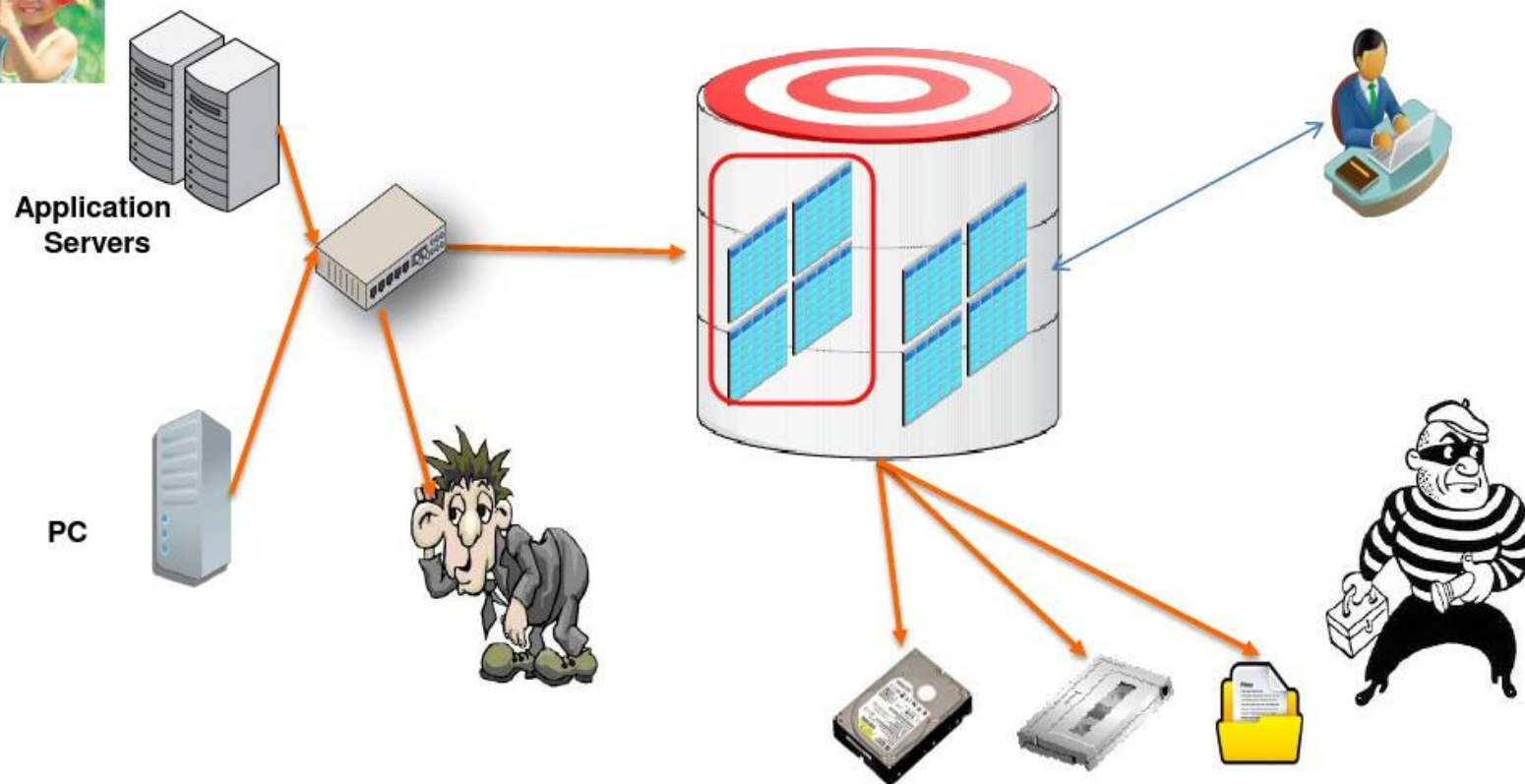


武装到牙齿，但一头一尾并不安全



获取/修改/损坏业务数据的途径

Sniff , 应用访问, 直接数据库访问, 数据库文件拷贝



4.1 数据库安全性概述

- 计算机系统安全性，指为计算机系统建立和采取的各种安全保护措施，以保护计算机系统硬件、软件及数据，防止其因偶然或恶意的原因使系统遭到破坏，数据遭到更改或泄露等。
- 数据库中数据的共享是在**DBMS**统一的严格的控制之下的共享，即只允许有合法使用权限的用户访问允许他存取的数据。
- 数据库系统的安全保护措施是否有效是数据库系统主要的性能指标之一。



4.1 数据库安全性概述

■ 计算机系统安全性问题可以分成三大类：

□ 技术安全类

□ 管理安全类

□ 政策法律类

软硬件意外故障、场地的意外事故、管理不善

政府部门建立的有关计算机犯罪、数据安全保密的法律道德准则和政策法规、法令。

路。



4.1.1 数据库不安全因素

■ 非授权用户对数据库的恶意存取和破坏

- 一些黑客（**Hacker**）和犯罪分子在用户存取数据库时猎取用户名和用户口令，然后假冒合法用户偷取、修改甚至破坏用户数据。
- 数据库管理系统提供的安全措施主要包括用户身份鉴别、存取控制和视图等技术。

■ 数据库中重要或敏感的数据被泄露

- 黑客和敌对分子千方百计盗窃数据库中的重要数据，一些机密信息被暴露。
- 数据库管理系统提供的主要技术有强制存取控制、数据加密存储和加密传输等。 --脱敏
- 审计日志分析



4.1.1 数据库不安全因素

■ 安全环境的脆弱性

- 数据库的安全性与计算机系统的安全性紧密联系：计算机硬件、操作系统、网络系统等的安全性

数据库中有网络接口，如果黑客想要利用它们就可以很轻易地操纵数据库中的这些网络接口。

数据库防火墙、堡垒机。

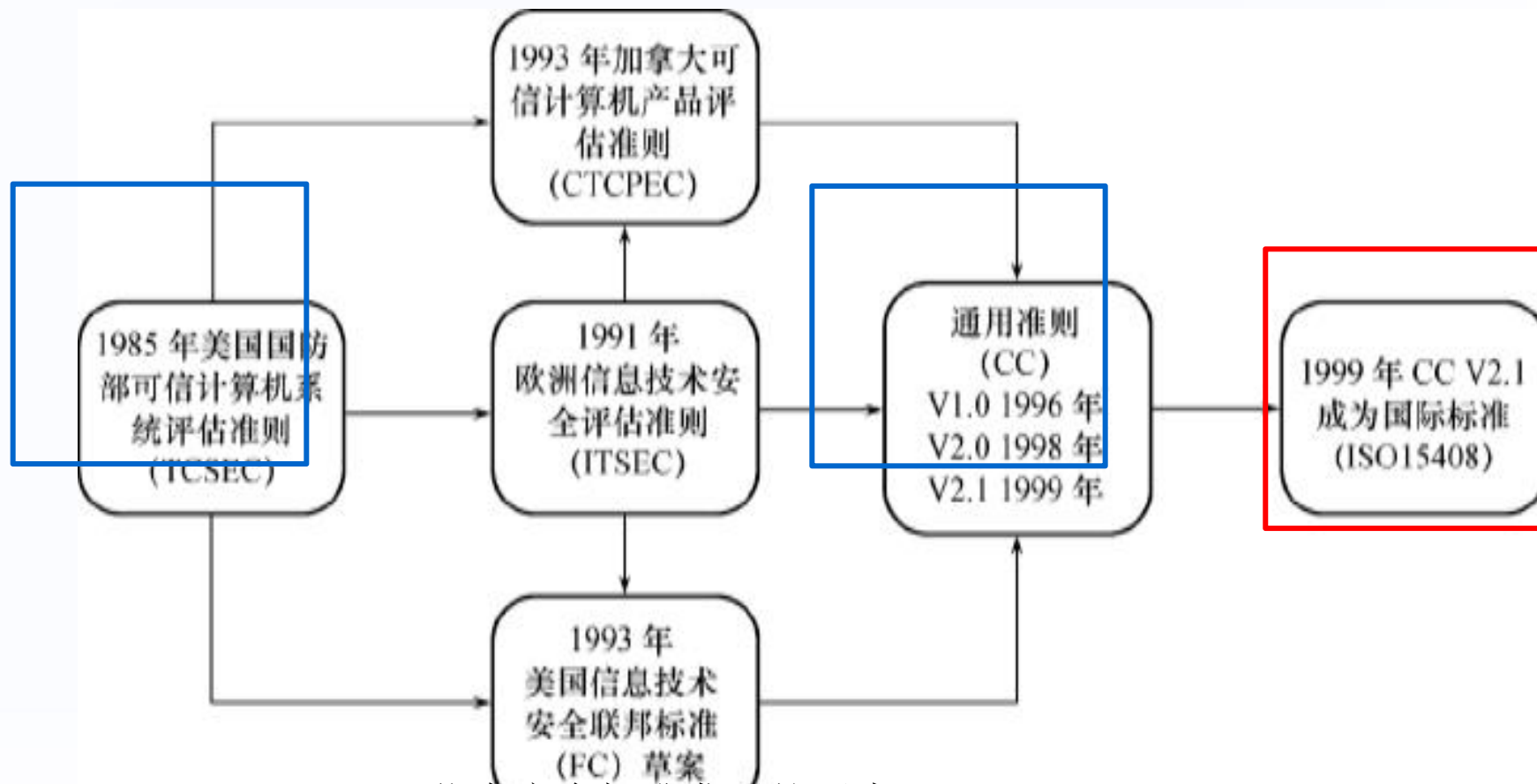
- 建立一套可信（**Trusted**）计算机系统的概念和标准



4.1.2 安全标准简介

■ TCSEC标准

■ CC标准



4.1.2 安全标准简介

■ 为降低进而消除对系统的安全攻击，各国引用或制定了一系列安全标准

✓ **TCSEC** (Trust Computer System Evaluation Criteria)

(桔皮书)

✓ **TDI** (**Trusted Database Interpretation**) (紫皮书)

■ **TCSEC (桔皮书)**

1985年美国国防部（DoD）正式颁布《DoD可信计算机系统评估标准》（简称**TCSEC**或**DoD85**）。提供一种标准，使用户可以对其计算机系统内敏感信息安全操作的**可信程度**做评估。



TDI (紫皮书)简介

✓ TDI (紫皮书)

1991年4月美国NCSC（国家计算机安全中心）颁布了《可信计算机系统评估标准关于可信数据库系统的解释》（Trusted Database Interpretation 简称TDI。TDI又称紫皮书。它将TCSEC扩展到数据库管理系统。TDI中定义了数据库管理系统的设计与实现中需满足和用以进行安全性级别评估的标准。



TCSEC/TDI安全级别划分

■ TDI/TCSEC标准的基本内容

TDI与TCSEC一样，从四个方面来描述安全性
级别划分的指标

- 安全策略
- 责任
- 保证
- 文档

安全级别	定 义
A1	验证设计 (Verified Design)
B3	安全域 (Security Domains)
B2	结构化保护 (Structural Protection)
B1	标记安全保护 (Labeled Security Protection)
C2	受控的存取保护 (Controlled Access Protection)
C1	自主安全保护 (Discretionary Security Protection)
D	最小保护 (Minimal Protection)



系统可靠或信程度逐渐增高



TCSEC/TDI安全级别划分（续）

■ 四组(division)七个等级

D

C（C1，C2）

B（B1，B2，B3）

A（A1）

按系统可靠或可信程度逐渐增高

各安全级别之间具有一种偏序向下兼容的关系，即较高安全性级别提供的安全保护要包含较低级别的所有保护要求，同时提供更多或更完善的保护能力。



TCSEC/TDI安全级别划分（续）

■ D级

➤ 将一切不符合更高标准的系统均归于D组

典型例子：DOS是安全标准为D的操作系统

DOS在安全性方面几乎没有什么专门的机制来保障。



TCSEC/TDI安全级别划分（续）

■ C1级

- 非常初级的自主安全保护
- 能够实现对用户和数据的分离，进行自主存取控制（**DAC**），保护或限制用户权限的传播。
- 现有的商业系统稍作改进即可满足



TCSEC/TDI安全级别划分（续）

■ C2级

- 是安全产品的最低档次
- 提供受控的存取保护，将C1级的DAC进一步细化，以个人身份注册负责，并实施审计和资源隔离
- 达到C2级的产品在其名称中往往不突出“安全”（**Security**）这一特色
- 典型例子

Windows 2000

Oracle 11g



TCSEC/TDI安全级别划分（续）

■ B1级

- 标记安全保护。“安全”（**Security**）或“可信的”（**Trusted**）产品。
- 对系统的数据加以标记，对标记的主体和客体实施强制存取控制（**MAC**）、审计等安全机制
- **B1级典型例子**
 - ✓ 操作系统
 - ✓ 惠普公司的HP-UX BLS release 9.09+
 - ✓ 数据库
 - ✓ Oracle公司的Trusted Oracle
 - ✓ Sybase公司的Secure SQL Server version 11.0.6



TCSEC/TDI安全级别划分（续）

■ B2级

- 结构化保护
- 建立形式化的安全策略模型并对系统内的所有主体和客体实施

DAC和MAC

■ B3级

- 安全域
- 该级的**TCB**必须满足访问监控器的要求，审计跟踪能力更强，并提供系统恢复过程

■ A1级

- 验证设计，即提供**B3级**保护的同时给出系统的形式化设计说明和验证以确信各安全保护真正实现。



■ CC

- 提出国际公认的表述信息技术安全性的结构
- 把信息产品的安全要求分为
 - ✓ 安全功能要求
 - ✓ 安全保证要求

■ CC评估保证级（EAL）划分

评估保证级	定 义	TCSEC安全级别 (近似相当)
EAL1	功能测试	C1
EAL2	结构测试	
EAL3	系统地测试和检查	
EAL4	系统地设计、测试和复查	B1
EAL5	半形式化设计和测试	B2
EAL6	半形式化验证的设计和测试	B3
EAL7	形式化验证的设计和测试 (formally verified design and tested)	A1

保证程度逐渐提高



第4章 数据库的安全性

4.1 计算机安全性概述

4.2 数据库安全性控制

4.3 视图机制

4.4 审计 (Audit)

4.5 数据加密

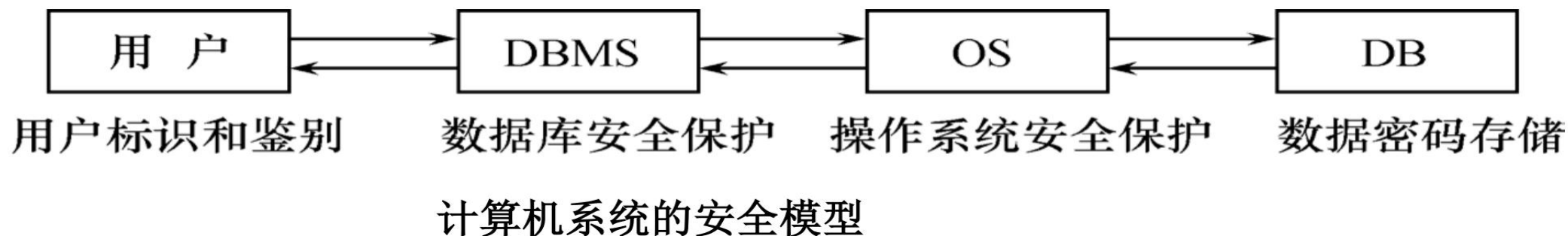
4.6 小结

- ①用户标识和鉴定
- ②存取控制
- ③自主存取控制方法
- ④授权与回收
- ⑤数据库角色
- ⑥强制存取控制方法



4.2 数据库安全性控制

■ 计算机系统中，安全措施是一级一级层层设置



- 系统根据用户标识鉴定用户身份，合法用户才准许进入计算机系统
- 数据库管理系统进行存取控制，只允许用户执行合法操作
- 操作系统有自己的保护措施
- 数据以密码形式存储到数据库中



数据库安全性控制（续）

■ DBMS的安全机制

➤ 自主安全性机制：存取控制(Access Control)

通过权限在用户之间的传递，使用户自主管理数据库安全性

➤ 强制安全性机制：

通过对数据和用户强制分类，使得不同类别用户能够访问不同类别的数据

➤ 推断控制机制：(可参阅相关文献)

✓ 防止通过历史信息，推断出不该被其知道的信息；

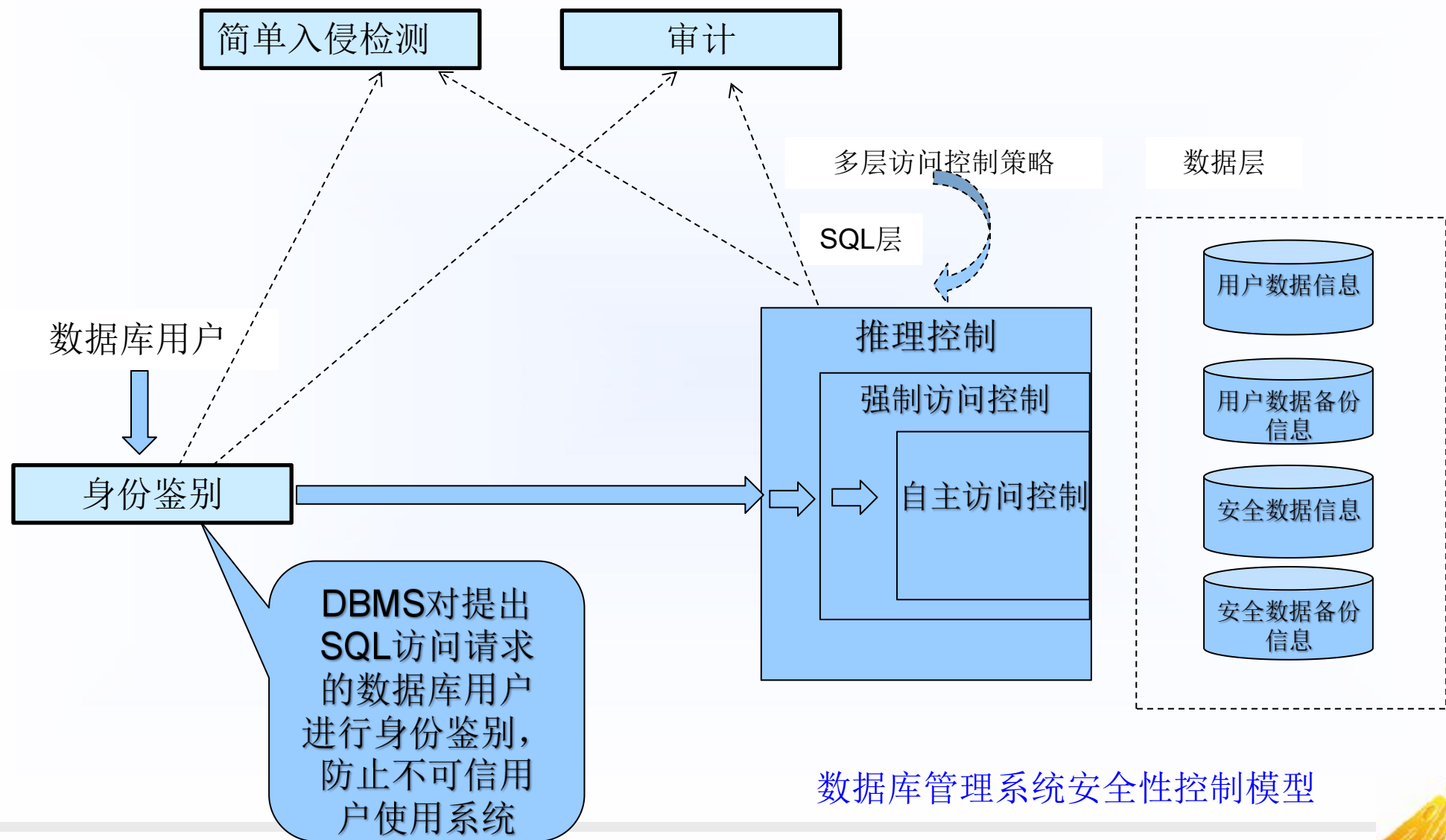
✓ 防止通过公开信息(通常是一些聚集信息)推断出私密信息(个体信息)，通常在一些由个体数据构成的公共数据库中此问题尤为重要

➤ 数据加密存储机制：(可参阅相关文献)

通过加密、解密保护数据，密钥、加密/解密方法与传输。



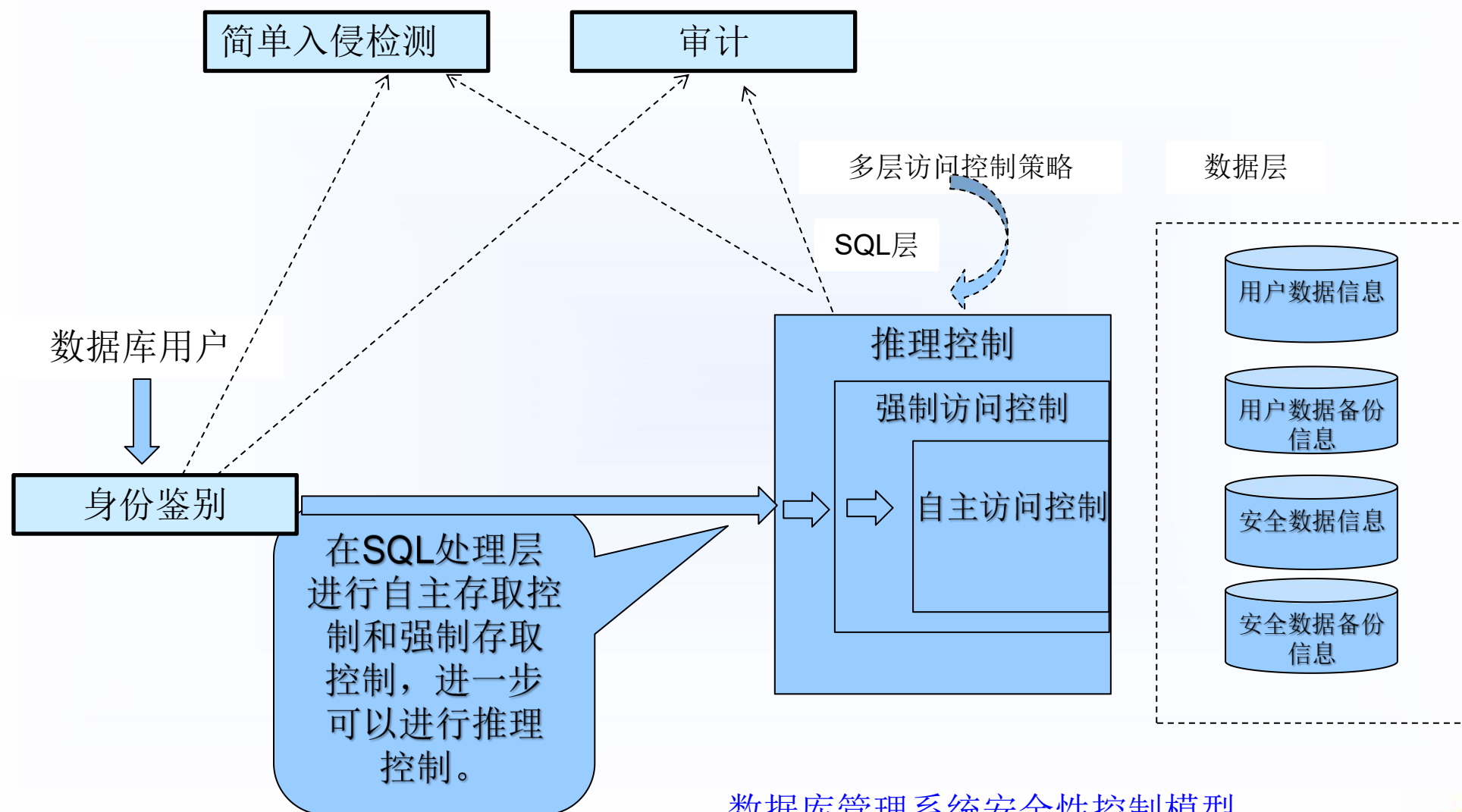
数据库安全性控制（续）



数据库管理系统安全性控制模型



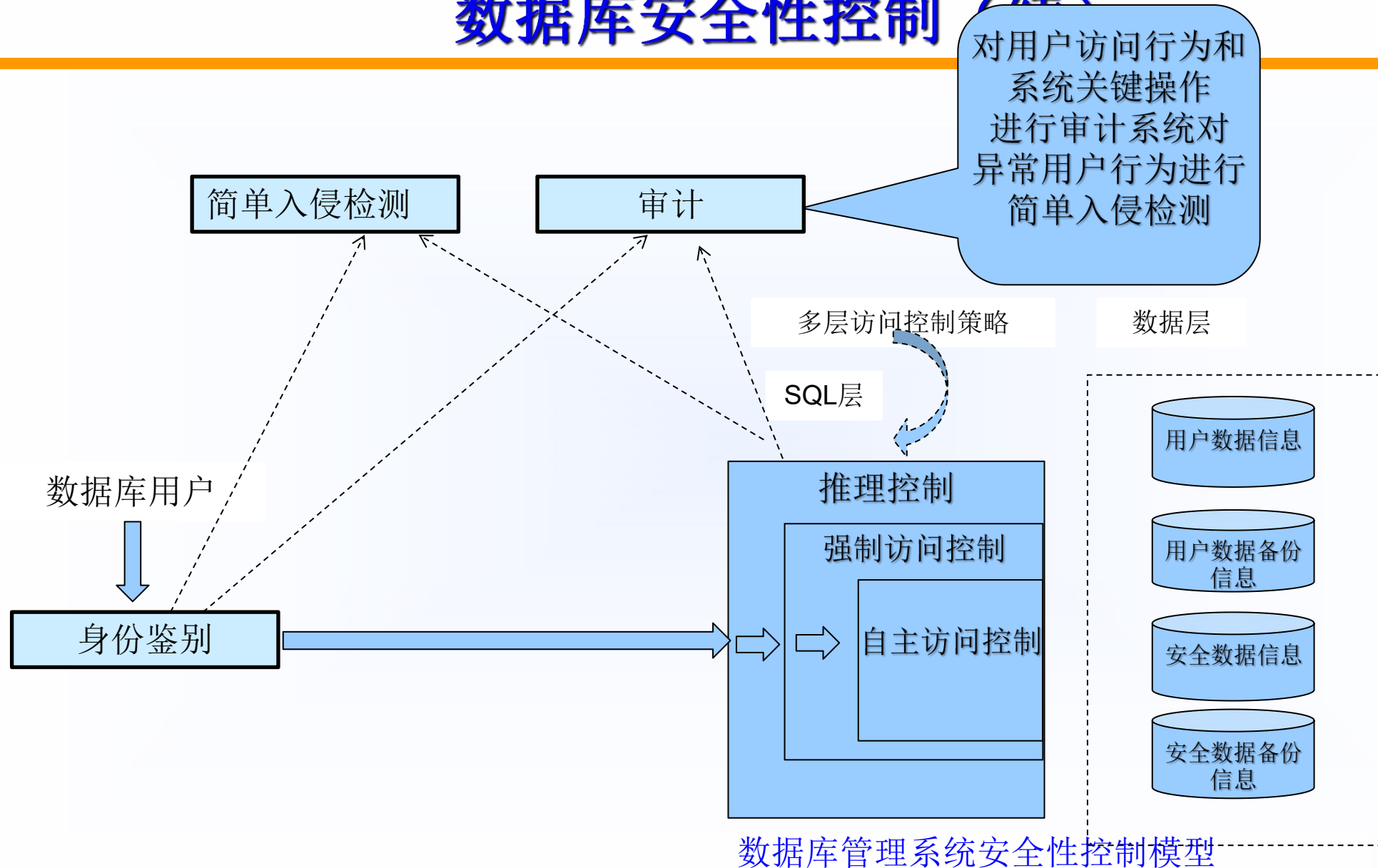
数据库安全性控制（续）



数据库管理系统安全性控制模型

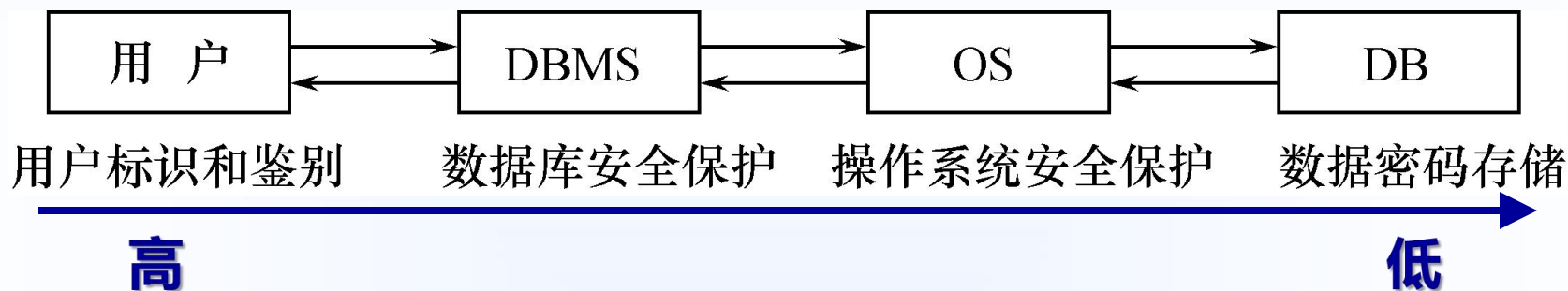


数据库安全性控制 (续)



数据库安全性控制（续）

- 在计算机系统中，安全措施是一级一级层层设置的



- 数据库的安全性可以划分为

三个层次：

- ✓ 网络系统的安全
- ✓ 操作系统的安全
- ✓ 数据库管理系统的安全

- 数据库安全性控制的常用方法包括：

- 用户标识和鉴别
- 存取控制
- 视图
- 审计
- 密码存储 等等



数据库安全性控制（续）

■ 非法使用数据库的情况包括：

- 用户编写一段合法的程序绕过DBMS及其授权机制，通过操作系统直接存取、修改或备份数据库中的数据
- 直接或编写应用程序执行非授权操作
- 通过多次合法查询数据库从中推导出一些保密数据

例如：某数据库应用系统禁止查询个人的工资，但允许查任意一组人的平均工资。用户甲想了解张三的工资，于是他：

- 1、首先查询包括张三在内的一组人的平均工资
- 2、然后查用自己替换张三后这组人的平均工资
- 3、从而推导出张三的工资

■ 破坏安全性的行为可能是无意的、故意的，或恶意的。



数据库安全性控制（续）

■ 数据库安全技术的研究

- ✓ 数据加密技术
- ✓ 用户认证技术
- ✓ 访问控制技术
- ✓ 防注入(Injection)技术

如：SQL Injection，利用某些数据库的外部接口将用户数据插入到实际的数据库操作语言当中，从而达到入侵数据库乃至操作系统的目的。



4.2 数据库安全性控制

4.2.1 用户标识与鉴别(Identification & Authentication)

4.2.2 存取控制

4.2.3 自主存取控制(DAC)方法

4.2.4 授权(Authorization)与回收

4.2.5 数据库角色

4.2.6 强制存取控制(MAC)方法



4.2.1 用户标识和鉴别

■ 用户标识与鉴别（Identification & Authentication）

系统提供的最外层安全保护措施。

■ 基本方法是：

- 系统提供一定的方式让用户标识自己的名字或身份；
- 系统内部记录着所有合法用户的标识；
- 每次用户要求进入系统时，由系统核对用户提供的身份标识；
- 通过鉴定后才提供机器使用权。
- 用户标识和鉴定可以重复多次。



4.2.1 用户标识和鉴别

1. 用户标识（User Identification）

用一个用户名（User Name）或用户标识号（UID）来标明用户身份。

2. 口令（Password）

系统核对口令以鉴别用户身份。

通过用户名和口令的方法简单易行，但这些信息容易被人窃取。可以采取更复杂的方法——**每个用户预先约定好一个计算过程或者函数**。（动态口令）

- 系统提供一个随机数
- 用户根据自己预先约定的计算过程或者函数进行计算
- 系统根据用户计算结果是否正确鉴定用户身份

3. 生物特征鉴别

4. 智能卡鉴别



4.2.2 存取控制

- 数据库安全性所关心的主要是**DBMS**的存取控制机制。
- 数据库安全最重要的一点就是**确保只授权给有资格的用户访问数据库的权限**，同时令所有未授权的人员无法接近数据，这主要通过数据库系统的存取控制机制实现。
- 存取控制机制主要包括两部分：
 - **定义用户权限**
 - ✓ 用户对某一数据对象的操作权力称为权限
 - ✓ **DBMS**提供适当的语言来定义用户权限，存放在数据字典中，称做安全规则或授权规则
 - **合法权限检查**
 - ✓ 用户发出存取数据库操作请求
 - ✓ **DBMS**查找数据字典，进行合法权限检查
- **用户权限定义和合法权检查机制一起组成了DBMS的安全子系统**



4.2.2 存取控制

■ 常用存取控制方法有：

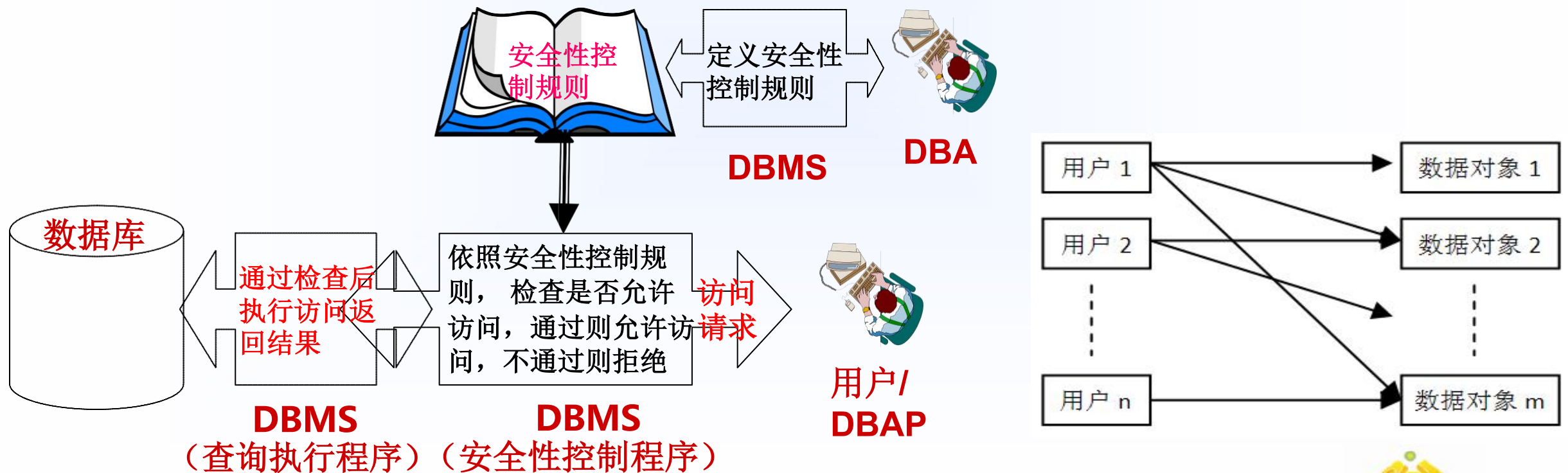
- **自主存取控制**（Discretionary Access Control，简称DAC），**C2级，灵活**
 - ★ 同一用户对于不同的数据对象有不同的存取权限
 - ★ 不同的用户对同一对象也有不同的权限
 - ★ 用户还可将其拥有的存取权限转授给其他用户
 - ★ 通过 SQL 的**GRANT** 语句和**REVOKE** 语句实现
- **强制存取控制**（Mandatory Access Control，简称 MAC），**B1级、严格**
 - ★ 每一个数据对象被标以一定的密级
 - ★ 每一个用户也被授予某一个级别的许可证
 - ★ 对于任意一个对象，只有具有合法许可证的用户才可以存取



4.2.3 自主存取控制

■ 自主访问控制方法

- DBMS允许用户定义一些安全性控制规则(用SQL-DCL来定义)
- 当有DB访问操作时，DBMS自动按照安全性控制规则进行检查，检查通过则允许访问，不通过则不允许访问。



4.2.3 自主存取控制

- SQL语言包含了DDL, DML和DCL。数据库安全性控制是属于DCL范畴
- 授权机制---自主安全性；视图的运用
- 关系级别(普通用户) ← 账户级别(程序员用户) ← 超级用户(DBA)

□ (级别1)Select 读(读DB, Table, Record, Attribute, ...)

□ (级别2)Modify: 更新

✓ Insert : 插入

✓ Update : 更新

✓ Delete : 删除

□ (级别3)Create: 创建(创建表空间、模式、表、索引、视图等)

✓ Create : 创建

✓ Alter : 更新

✓ Drop : 删除

- 级别高的权利自动包含级别低的权利。如某人拥有更新的权利，它也自动 拥有读的权利。在有些DBMS中，将级别3的权利称为账户级别的权利，而将级别1和2称为关系级别的权利。



4.2.3 自主存取控制方法

- 定义存取权限要素
 - ✓ 数据对象
 - ✓ 操作类型
- 关系数据库系统中的存取权限类型

对象数据	对象	
数据库	模式	CREATE DATA
	基本表	CREATE
模式	视图	C
	索引	CF
数据	基本表和视图	SELECT,INSERT,UP AL
	属性列	SELECT,INSERT, F

表属性 - Td_zzmmdm

选择页

常规

权限

更改跟踪

存储

扩展属性

脚本

帮助

架构(S):

dbo

查看架构权限

表名(N):

Td_zzmmdm

用户或角色(U):

搜索

名称

类型

guest

用户

guest 的权限(E):

列权限(C)...

显式

有效

权限

授权者

授予

具有授予...

拒绝

插入

dbo

☒

☒

查看定义

dbo

☒

☐

查看更改跟踪

dbo

☒

☐

更改

dbo

☐

☐

更新

dbo

☒

☐

接管所有权

dbo

☐

☐

连接

服务器:

DESKTOP-U2BTSAG\SQLEXPRESS

连接:

DESKTOP-U2BTSAG\humin

查看连接属性

进度

已成功完成脚本操作。



4.2.3 用户权限设置

✓ 关系数据库系统中访问控制对象

对象类型	对象	操作类型
数据库	模式	CREATE SCHEMA
	基本表	CREATE TABLE, ALTER TABLE
模式	视图	CREATE VIEW
	索引	CREATE INDEX
数据	基本表和视图	SELECT, INSERT, UPDATE, DELETE, REFERENCES, ALL PRIVILEGES
数据	属性列	SELECT, INSERT, UPDATE, REFERENCES, ALL PRIVILEGES



4.2.3 自主存取控制方法

■ 关系系统中的存取权限定义方法

GRANT/REVOKE

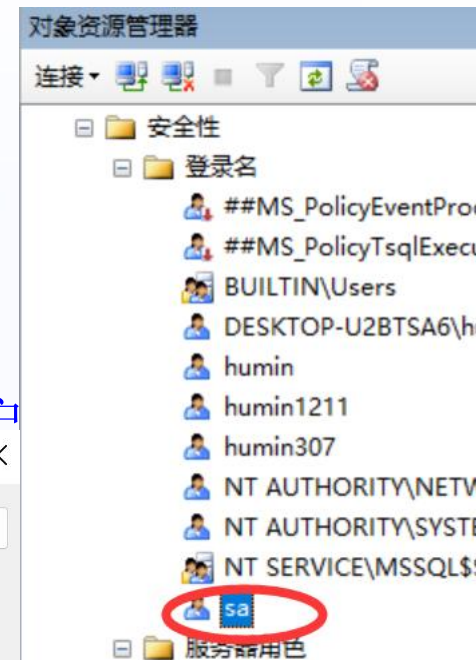
■ DBMS专门提供一个DBA账户

该账户是一个超级用户或称系统用户。DBA利用该账户的特权可以进行用户管理

予和撤消、安全

■ DBMS实现数

1. 用户或DBA
2. SQL的GRAN
3. DBMS把授
4. 当用户提出



灵授

行操作请求



4.2.4 授权(Authorization)与回收

■ 授权权限GRANT

一般格式:

GRANT <权限>[, <权限>]...

[ON <对象名>]

TO <用户>[, <用户>].

[WITH GRANT OPTION];

指定该子句: 可以再转授权限
没有指定: 不能传播权限
具有授权的权限

谁定义? DBA和表的建立者 (即表的属主)

GRANT功能: 将对指定操作对象的指定操作权限授予指定的用户。



4.2.4 授权与回收

■ 谁可以发出GRANT:

➤ DBA、对象创建者（Owner）、拥有该权限的用户。

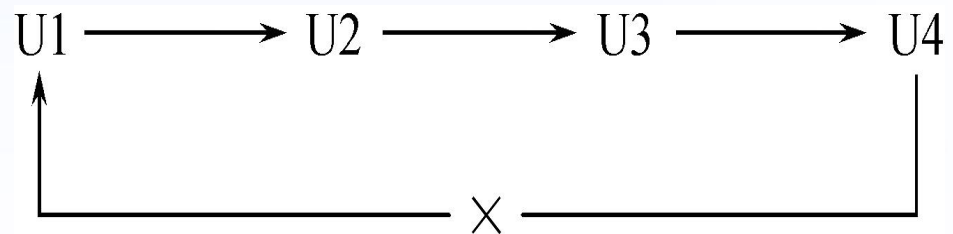
■ 可接受权限的用户：

➤ 一个或多个具体用户、PUBLIC（全体用户）。

■ WITH GRANT OPTION子句

获得某种权限的用户还可以把这种权限再授予别的用户

□ 不允许循环授权:



4.2.4 授权与回收

■ 安全性设置实例：

授权过程

1. 创建新用户u1,u2,u3,u4,u5
2. 授予用户u1,u2,u3,u4,u5权限connect
3. 授予用户特定的对象权限



4.2.4 授权与回收

[例1] 将查询Students表的select权限授给用户U1。

```
GRANT SELECT ON table Students TO U1;
```

[例2] 将对Students表和Course表的全部权限授予用户U2和U3。

```
GRANT ALL PRIVILEGES ON TABLE Students, Course TO U2, U3;
```

[例3] 将对表SC的查询权限授予所有用户。

```
GRANT SELECT ON TABLE SC TO PUBLIC;
```

[例4] 将查询Students表和修改学生学号的权限授给用户U4。

```
GRANT UPDATE(Sno), SELECT ON TABLE Students TO U4;
```

[例5] 将SC的INSERT权限授予U5，并允许他将此权限授予其他用户。

```
GRANT INSERT ON TABLE SC TO U5 WITH GRANT OPTION;
```

U5还可以将此权限授予U6，。。。



传播权限

执行例5后，U5不仅拥有了对表SC的INSERT权限， 还可以传播此权限：U5还可以将此权限授予U6，。。。

[例6] GRANT INSERT
 ON TABLE SC TO U6 WITH GRANT OPTION;

[例7] 同样U6还可以将此权限授予U7。
 GRANT INSERT ON TABLE SC TO U7;;

但U7不能再传播此权限。;



4.2.4 授权与回收

■ 撤销 (收回) 权限

授予的权限可以由DBA或其他授权者用REVOKE语句收回

➤ REVOKE语句的一般格式为:

REVOKE <权限>[, <权限>]...

[ON <对象类型> <对象名>]

FROM <用户>[, <用户>]...

[**CASCADE** | **RESTRICT**]

不同DBMS的缺省值
不相同



4.2.4 授权与回收

[例8] 把用户U4修改学生学号的权限收回。

```
REVOKE UPDATE(Sno) ON TABLE Students FROM U4;
```

[例9] 收回所有用户对表SC的查询权限。

```
REVOKE SELECT ON TABLE SC FROM PUBLIC;
```

[例10] 把用户U5对SC表的INSERT权限收回。

```
REVOKE INSERT ON TABLE SC FROM U5 CASCADE ;
```

- 如果系统缺省值为RESTRICT，回收U5的INSERT权限时应该使用CASCADE短语，否则拒绝执行该语句
- 如果U6或U7还从其他用户处获得对SC表的INSERT权限，则他们仍具有此权限，系统只收回直接或间接从U5处获得的权限



4.2.4 授权与回收

■ 创建数据库模式的权限

- **DBA**在创建用户时实现！

不是SQL标准，各DBMS产品会有所不同

CREATE USER <username>
[WITH] [DBA | RESOURCE | CONNECT]

拥有的权限	可否执行的操作			
	CREATE USER	CREATE SCHEMA	CREATE TABLE	登录数据库 执行数据查询 和操纵
DBA	可以	可以	可以	可以
RESOURCE	不可以	不可以	可以	可以
CONNECT	不可以	不可以	不可以	可以，但必须拥有相应权限



4.2.4 授权与回收

Oracle 授权机制:

■ 创建用户

create user <用户名> identified <by 口令>;

■ 授予用户系统权限

grant create table, create view, create synonym,
create sequence, create trigger, create index, create
procedure to <用户|角色> [with admin option];

■ 授予用户对象权限

grant select,delete,update,insert on <表名>
to 用户|角色|public [with grant option];

MySQL 创建用户

■ CREATE USER [IDENTIFIED BY [PASSWORD] 'password'] [,用户 [IDENTIFIED BY [PASSWORD] 'password']]



小结

■ 数据库安全性控制的常用方法

- 用户身份鉴别
- 存取控制
 - ✓ 自主存取控制
 - ✓ 强制存取控制
- 视图
- 审计
- 数据加密



To be continued
Practice makes perfect!



厚德

笃学

崇实

尚新

下课了。。



休息。。。。

